

ACTA DE ENTREGA-RECEPCIÓN

Playbook 1 de 18 - Hardening CIS Red Hat Enterprise Linux 9

Acta N.º	_____ (completar)	Fecha de elaboración	8 de octubre de 2026
Ciente	Banco Solidario	Proveedor	GMS - Práctica Red Hat / Ansible
Proyecto	Desarrollo de 18 Playbooks de automatización con Ansible/AWX	Playbook entregado	N.º 1 - CIS RHEL 9 Benchmark v2.0.0, Nivel 1 + Nivel 2, perfil Server
Repositorio	github.com/Soporte-SI/HARDENING-RE DHAT-9 (rama main)	Commit / etiqueta entregada	Código Completado

1. Objeto del acta

Mediante la presente acta, GMS hace entrega formal a Banco Solidario del **Playbook 1 - Hardening CIS RHEL 9**, desarrollado como parte del proyecto de 18 playbooks de automatización con Ansible, junto con su código fuente, documentación y matriz de cobertura, y Banco Solidario deja constancia de su recepción conforme al detalle descrito a continuación.

2. Objetivo del playbook

Aplicar de forma **automatizada, idempotente y auditable** el **CIS Red Hat Enterprise Linux 9 Benchmark v2.0.0** (Nivel 1 + Nivel 2, perfil Server) sobre los servidores RHEL 9 del banco, reemplazando el endurecimiento manual por una ejecución repetible, con trazabilidad por control CIS, posibilidad de simulación previa (--check --diff) y excepciones documentadas por control. El rol fue desarrollado a medida: no depende de roles community de terceros (solo colecciones ansible.posix, community.general y community.crypto).

3. Alcance y cobertura entregada

Concepto	Nivel 1	Nivel 2	Total
Controles Automated (según CIS)	217	58	275
Controles Manual (según CIS)	18	4	22
Total controles del benchmark	235	62	297

Estado en la matriz de cobertura	Cantidad	Significado
implemented	241	Remediación activa e idempotente (o auditoría no destructiva cuando la remediación automática implicaba riesgo de negocio).
excluded_baseline_cliente	34	Controles que no figuran en la línea base entregada por el banco (Línea_Base_Hardening_CIS_RHEL9_Final.xlsx, 2026-08-07). El código se conserva pero queda deshabilitado por defecto (toggle = false).
manual	22	Marcados Manual por el propio CIS (política organizacional o revisión humana). No se automatizan; quedan documentados para seguimiento.
Total	297	Cada ID del benchmark aparece exactamente una vez en docs/coverage_matrix.csv.

Nota: el control 5.4.2.4 (acceso a la cuenta root) es Automated según CIS pero se deja como manual en este rol, porque su remediación depende de la política de acceso de emergencia ("break-glass") del banco.

4. Lógica de funcionamiento

El playbook sigue un flujo lineal de seis etapas. Cada control CIS es una tarea con su propio ID, protegida por dos compuertas: el **nivel CIS** (`rhel9cis_level`) y un **toggle individual** (`rhel9cis_rule_<id>`). Si cualquiera de las dos es falsa, el control no se ejecuta.



Mecanismos de control

Mecanismo	Cómo funciona
Nivel CIS	<code>rhel9cis_level</code> : 1 = solo Nivel 1; 2 = Nivel 1 + Nivel 2 (valor del banco). Con 1, ningún control de Nivel 2 se ejecuta aunque se pida por tag.
Toggle por control	Un booleano <code>rhel9cis_rule_<id_con_guiones_bajos></code> por control (p. ej. <code>rhel9cis_rule_1_1_1_8</code>). Las excepciones se declaran en <code>group_vars</code> /host_vars con el ticket/CR asociado; nunca editando defaults.
Tags	Cada tarea lleva su ID CIS (5.1.20), su sección (<code>section5</code>) y su nivel (<code>level1/level2</code>). Permiten ejecutar o excluir un control, un grupo o una sección completa.
Modo simulación	<code>--check</code> <code>--diff</code> muestra qué se modificaría sin aplicar cambios (tareas con grubby/authselect pueden reportar "changed" sin diff real).
Controles de auditoría	Donde la remediación automática implica riesgo (p. ej. NOPASSWD en sudo, archivos world-writable, UID 0 adicionales) la tarea solo reporta hallazgos; la corrección es manual.
Idempotencia	Todas las tareas usan módulos con estado; una segunda corrida sin cambios en el host no debe modificar nada.
Un solo firewall	<code>rhel9cis_firewall_utility</code> = firewalld (recomendado) o nftables; la utilidad no elegida se enmascara (CIS 4.1.2).

5. Diagrama de archivos del repositorio

```
rhel9-cis-hardening-ansible/
|-- ansible.cfg                # Config de Ansible (inventario, SSH, become, cache)
|-- requirements.yml           # Colecciones requeridas
|-- site.yml                   # Playbook principal (entry point)
|-- README.md                  # Guía de uso y cobertura
|-- inventory/
|   |-- hosts.example.ini      # Plantilla de inventario (grupo [rhel9]) -> copiar a hosts.ini
|-- group_vars/
|   |-- all.yml                # Variables del entorno: nivel CIS, firewall, password GRUB
|-- docs/
|   |-- coverage_matrix.csv    # 297 controles, uno por fila, con estado y tag asociado
|-- roles/rhel9_cis_hardening/
|   |-- meta/main.yml          # Metadatos del rol
|   |-- defaults/main.yml      # Nivel CIS + toggle booleano por control
|   |-- tasks/
|       |-- main.yml           # Orquestador: lee UID_MIN e incluye las 6 secciones
|       |-- section1_initial_setup.yml    # CIS 1 - Initial Setup
|       |-- section2_services.yml         # CIS 2 - Services
|       |-- section3_network.yml          # CIS 3 Network + CIS 4 Firewall
|       |-- section4_logging_auditing.yml # CIS 6 - Logging and Auditing
|       |-- section5_access_authentication.yml # CIS 5 - Access, Authentication, Authorization
|       |-- section6_system_maintenance.yml # CIS 7 - System Maintenance
|-- vars/                          # Datos estructurados (listas) que consumen las tasks
|   |-- section1_filesystem.yml, section2_services.yml, section3_network.yml
|   |-- section4_firewall.yml, section5_accounts.yml, section5_pam.yml
|   |-- section5_ssh.yml, section6_auditd_rules.yml
|-- handlers/main.yml              # Reinicios/recargas condicionados a cambios
|-- templates/                     # Plantillas Jinja2
|   |-- banner.j2, nftables-cis.j2
|   |-- gdm-cis-locks.j2, gdm-cis-settings.j2
```

6. Función de cada archivo

6.1 Archivos de raíz y configuración

Archivo	Función
site.yml	Entry point. Play sobre el grupo <code>rhel9</code> con <code>become</code> . <i>pre_tasks</i> : verifica SO compatible y recolecta paquetes. Ejecuta el rol. <i>post_tasks</i> : avisa si se requiere reinicio.
ansible.cfg	Inventario por defecto, <code>roles_path</code> , host key checking, SSH con <code>pipelining</code> y <code>ControlPersist</code> , fact caching en jsonfile (1 h), formato de resultado YAML.
requirements.yml	Colecciones requeridas: <code>ansible.posix</code> ($\geq 1.5.4$), <code>community.general</code> ($\geq 8.0.0$), <code>community.crypto</code> ($\geq 2.16.0$).
inventory/hosts.example.ini	Ejemplo de inventario con el grupo <code>[rhel9]</code> , usuario de servicio y <code>python3</code> . Se copia a <code>hosts.ini</code> con los hosts reales.
group_vars/all.yml	Parámetros del entorno: nivel CIS (2), perfil server, utilidad de firewall (<code>firewalld</code>), password GRUB (vacío; debe ir en Ansible Vault).
docs/coverage_matrix.csv	Evidencia de cobertura: id, título, nivel, tipo CIS, estado (<code>implemented</code> / <code>excluded_baseline_cliente</code> / <code>manual</code>), tag y notas.
README.md	Manual de uso: requisitos, inventario, ejecución, tags, excepciones, variables, advertencias y resumen de cobertura.

6.2 Rol rhel9_cis_hardening - tareas

Archivo	Sección CIS	Qué hace
tasks/main.yml	-	Orquestador. Lee UID_MIN de /etc/login.defs (base para reglas de auditd y cuentas de sistema) e incluye cada sección con su tag.
section1_initial_setup.yml	1	Módulos de kernel de filesystems, particiones y opciones de montaje (nodev/nosuid/noexec), actualizaciones, SELinux, bootloader, hardening de procesos, crypto-policy, banners, GDM.
section2_services.yml	2	Detiene, deshabilita y enmascara servicios innecesarios; verifica paquetes cliente; configura chrony, cron y at.
section3_network.yml	3 y 4	Dispositivos y módulos de kernel de red, parámetros sysctl, y firewall (selección de utilidad única, firewalld o nftables).
section4_logging_auditing.yml	6	AIDE, systemd-journald (local y remoto), rsyslog y auditd (servicio, retención, reglas por control, permisos de logs). Nombre histórico del archivo; contenido = CIS 6.
section5_access_authentication.yml	5	SSH (5.1), sudo/su (5.2), PAM y authselect (5.3), cuentas y entorno de usuarios (5.4).
section6_system_maintenance.yml	7	Permisos de archivos del sistema y auditoría de cuentas/grupos locales. Nombre histórico del archivo; contenido = CIS 7.

6.3 Rol - variables, handlers, plantillas y metadatos

Archivo	Función
defaults/main.yml	Valores por defecto: nivel CIS, perfil, firewall, contenedor, SU group, listas de acceso SSH, host de logs remoto, y el toggle rhel9cis_rule_* de cada control (los 34 excluidos del baseline van en false).
vars/section1_filesystem.yml	Lista de módulos de kernel de filesystems a bloquear y datos de particiones.
vars/section2_services.yml	Servicios a no usar (detener + deshabilitar + enmascarar, sin desinstalar paquetes para no romper dependencias en producción).
vars/section3_network.yml	Módulos de kernel de red poco comunes (dccp, tipc, rds, etc.) y parámetros de red.
vars/section4_firewall.yml	Utilidades de firewall conocidas, para garantizar que solo una esté activa.
vars/section5_accounts.yml	Parámetros de /etc/login.defs (PASS_MAX_DAYS, PASS_WARN_AGE, ENCRYPT_METHOD, etc.).
vars/section5_pam.yml	Parámetros de pwquality (longitud mínima 14, repeticiones, diferencias, etc.).
vars/section5_ssh.yml	Directivas de sshd_config a fijar (ClientAlive*, DisableForwarding, etc.).
vars/section6_auditd_rules.yml	Reglas auditd: cada control genera su archivo /etc/audit/rules.d/50-<key>.rules, trazable por ID; la regla de inmutabilidad (99-finalize) se aplica al final.
handlers/main.yml	Reinicio/recarga de sshd, chronyd, crond, postfix, rsyslog, journald, firewalld, nftables, auditd; sysctl --system; grub2-mkconfig; authselect; dconf; remount de particiones. GRUB y auditd marcan <i>reboot required</i> .
templates/banner.j2	Banner de advertencia legal (/etc/issue, /etc/issue.net, motd).
templates/nftables-cis.j2	Reglas base nftables (solo si se elige nftables).
templates/gdm-cis-*.j2	Configuración y bloqueos de GDM/dconf (solo si GNOME está instalado).
meta/main.yml	Metadatos del rol: namespace gms_solidario, Ansible mínimo 2.15, plataforma EL 9, sin dependencias.

7. Uso y ejecución

Requisitos: control node con ansible-core >= 2.15, Python 3 y las colecciones de requirements.yml; hosts RHEL 9 (o Rocky/Alma/Oracle 9) con SSH, usuario con sudo y python3.

```
ansible-galaxy collection install -r requirements.yml
cp inventory/hosts.example.ini inventory/hosts.ini      # ajustar hosts reales

# 1) Simulación (siempre primero)
ansible-playbook -i inventory/hosts.ini site.yml --check --diff --ask-become-pass

# 2) Ejecución completa (Nivel 1 + Nivel 2)
ansible-playbook -i inventory/hosts.ini site.yml --ask-become-pass

# 3) Solo SSH / un control puntual / todo excepto auditd / solo Nivel 1
ansible-playbook -i inventory/hosts.ini site.yml --tags "5.1"
ansible-playbook -i inventory/hosts.ini site.yml --tags "5.1.20"
ansible-playbook -i inventory/hosts.ini site.yml --skip-tags "section6"
ansible-playbook -i inventory/hosts.ini site.yml -e "rhel9cis_level=1"
```

Mapeo de tags: section1 = CIS 1, section2 = CIS 2, section3/section4 = Red y Firewall, section5 = Acceso, section6 = Logging/Auditoría, section7 = Mantenimiento.

8. Consideraciones y advertencias de operación

- **Probar primero en no productivo.** El playbook modifica SSH, firewall, PAM, GRUB, auditd y crypto-policies; un error puede dejar un host inaccesible. Contar con consola fuera de banda (iLO/iDRAC/hipervisor).
- **Ventana de mantenimiento.** GRUB, auditd en modo inmutable y crypto-policies requieren reinicio para quedar activos; el playbook lo advierte al final (rhel9cis_reboot_required).
- **Secretos.** La contraseña de GRUB (rhel9cis_grub_password) debe gestionarse con Ansible Vault; nunca en texto plano en el repositorio.
- **Controles de auditoría.** Los hallazgos reportados (sudo NOPASSWD, world-writable, UID 0 adicionales, etc.) requieren remediación manual posterior a la revisión.
- **Excepciones.** Cualquier exclusión de un control se declara con su toggle en group_vars/host_vars, con el ticket o CR que la justifica.

9. Entregables

N.º	Entregable	Conforme
1	Código fuente del playbook (site.yml, rol rhel9_cis_hardening, inventario, variables) en el repositorio indicado	[]
2	Matriz de cobertura de 297 controles (docs/coverage_matrix.csv)	[]
3	README con instrucciones de instalación, ejecución, tags, variables y advertencias	[]
4	Explicación de la lógica y diagrama de archivos (esta acta)	[]

10. Observaciones

11. Conformidad

Las partes declaran haber revisado el contenido de la presente acta y firman en señal de entrega y recepción conforme.

ENTREGA - GMS	RECIBE - BANCO SOLIDARIO
Juan Pablo Castillo Cargo: Líder de Proyecto Fecha de elaboración del documento: 8 de octubre de 2026	Jeremy Moreno Cargo: Seguridad de la Información Fecha de elaboración del documento: 8 de octubre de 2026